

# Digital Policy Office

---

## INFORMATION SECURITY

---

### Practice Guide for Security Log Management

Version 1.2

July 2024

© The Government of the Hong Kong Special Administrative Region  
of the People's Republic of China

|                                                                                                                                                                                                                                              |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China.</p> |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## **COPYRIGHT NOTICE**

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

| Amendment History |                                                                                                                 |                              |                 |           |
|-------------------|-----------------------------------------------------------------------------------------------------------------|------------------------------|-----------------|-----------|
| Change Number     | Revision Description                                                                                            | Pages Affected               | Revision Number | Date      |
| 1                 | Elaboration of fields for logging printing and file transfer;<br>Description revised                            | 24;<br>13, 15, 21,<br>23, 27 | 1.1             | June 2021 |
| 2                 | Change “Office of the Government Chief Information Officer” (or “OGCIO” ) to “Digital Policy Office” (or “DPO”) |                              | 1.2             | July 2024 |

## Table of Contents

|     |                                                                 |    |
|-----|-----------------------------------------------------------------|----|
| 1.  | Introduction.....                                               | 1  |
| 1.1 | Purpose.....                                                    | 1  |
| 1.2 | Normative References.....                                       | 1  |
| 1.3 | Terms and Convention.....                                       | 1  |
| 1.4 | Contact .....                                                   | 2  |
| 2.  | Information Security Management .....                           | 3  |
| 3.  | Overview of Security Log Management.....                        | 5  |
| 3.1 | Importance of Security Log .....                                | 5  |
| 3.2 | Overview of Security Log Management.....                        | 5  |
| 4.  | Security Log Management .....                                   | 6  |
| 4.1 | Planning for Security Log Management .....                      | 6  |
| 4.2 | Security Log Lifecycle Management.....                          | 8  |
| 4.3 | Security Log Monitoring and Analysis.....                       | 16 |
| 4.4 | Security Information and Event Management (SIEM).....           | 17 |
|     | Annex A: Sample Checklist of Log Management Controls .....      | 18 |
|     | Annex B: Security Information and Event Management (SIEM) ..... | 30 |

## 1. Introduction

Security log is a primary source for analysis of a security event. It is also used to understand if there are any attempts to compromise information systems and data assets. It is also useful when conducting security audit, establishing security baselines, identifying operational needs and formulating long-term security planning.

### 1.1 Purpose

The purpose of this document is to provide common security considerations and best practices to B/Ds on the security log management.

This document should be used in conjunction with established government requirements and documents including the Baseline IT Security Policy [S17], the IT Security Guidelines [G3] and other relevant procedures and guidelines, where applicable.

### 1.2 Normative References

The following referenced documents are indispensable for the application of this document.

- Baseline IT Security Policy [S17], the Government of Hong Kong Special Administrative Region
- IT Security Guidelines [G3], the Government of Hong Kong Special Administrative Region
- Information technology – Security techniques – Information security management systems – Requirements (second edition), ISO/IEC 27001:2013
- Information technology – Security techniques – Code of practice for information security controls (second edition), ISO/IEC 27002:2013

### 1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

| Abbreviation and Terms |    |
|------------------------|----|
| NA                     | NA |

## 1.4 Contact

This document is produced and maintained by the Digital Policy Office (DPO). For comments or suggestions, please send to:

Email: [it\\_security@digitalpolicy.gov.hk](mailto:it_security@digitalpolicy.gov.hk)

Lotus Notes mail: IT Security Team/DPO/HKSARG@DPO

CMMP mail: IT Security Team/DPO

## 2. Information Security Management

Information security is about the planning, implementation and continuous enhancement of security controls and measures to protect the confidentiality, integrity and availability of information assets, whether in storage, processing, or transmission and its associated information systems. Information security management is a set of principles relating to the functions of planning, organising, directing, controlling, and the application of these principles in harnessing physical, financial, human and informational resources efficiently and effectively to assure the safety of information assets and information systems.

Information security management involves a series of activities that require continuous monitoring and control. These activities include but not limited to the following functional areas:

- Security Management Framework and the Organisation;
- Governance, Risk Management, and Compliance;
- Security Operations;
- Security Event and Incident Management;
- Awareness Training and Capability Building; and
- Situational Awareness and Information Sharing.

### **Security Management Framework and Organisation**

B/Ds shall establish and enforce departmental information security policies, standards, guidelines and procedures in accordance with the business needs and the government security requirements.

B/Ds shall also define the organisation structure on information security and provide clear definitions and proper assignment of security accountability and responsibility to involved parties.

### **Governance, Risk Management and Compliance**

B/Ds shall adopt a risk-based approach to identify, prioritise and address the security risks of information systems in a consistent and effective manner.

B/Ds shall perform security risk assessments for information systems and production applications periodically and when necessary so as to identify risks and consequences associated with vulnerabilities, and to provide a basis to establish a cost-effective security program and implement appropriate security protection and safeguards.

B/Ds shall also perform security audit on information systems regularly to ensure that current security measures comply with departmental information security policies, standards, and other contractual or legal requirements.

### **Security Operations**

To protect information assets and information systems, B/Ds should implement comprehensive security measures based on their business needs, covering different technological areas in their business, and adopt the principle of "Prevent, Detect, Respond and Recover" in their daily operations.

- Preventive measures avoid or deter the occurrence of an undesirable event;
- Detective measures identify the occurrence of an undesirable event;
- Response measures refer to coordinated actions to contain damage when an undesirable event or incident occurs; and
- Recovery measures are for restoring the confidentiality, integrity and availability of information systems to their expected state.

### **Security Event and Incident Management**

In reality, security incidents might still occur due to unforeseeable, disruptive events. In cases where security events compromise business continuity or give rise to risk of data security, B/Ds shall activate their standing incident management plan to identifying, managing, recording, and analysing security threats, attacks, or incidents in real-time. B/Ds should also prepare to communicate appropriately with relevant parties by sharing information on response for security risks to subdue distrust or unnecessary speculation. When developing an incident management plan, B/Ds should plan and prepare the right resources as well as develop the procedures to address necessary follow-up investigations.

### **Awareness Training and Capability Building**

As information security is everyone's business, B/Ds should continuously promote information security awareness throughout the organisations and arrange training and education to ensure that all related parties understand the risks, observe the security regulations and requirements, and conform to security best practices.

### **Situational Awareness and Information Sharing**

As cyber threat landscape is constantly changing, B/Ds should also constantly attend to current vulnerabilities information, threat alerts, and important notices disseminated by the security industry and the GovCERT.HK. The security alerts on impending and actual threats should be disseminated to and shared with those responsible colleagues within B/Ds so that timely mitigation measures could be taken.

B/Ds could make use of threat intelligence platforms to receive and share information regarding security issues, vulnerabilities, and cyber threat intelligence.



### **3. Overview of Security Log Management**

#### **3.1 Importance of Security Log**

Security log tracks security-related information such as records of login/logout activity, remote access and change of user privilege. Continuously monitoring of the security events and activities recorded in the security logs enables the timely detection of potential security breaches and intrusions. It also facilitates the administrators to identify the improvement areas to protect the information systems. Because of its ability to provide such information, security log is usually the primary information that the administrator will use to check if there is any security breach.

#### **3.2 Overview of Security Log Management**

In general, the security log management involves two major stages, namely:

- Planning
- Operation

Planning stage and other preparatory activities in security log management are important for creating a consistent and reliable log management practices. In this stage, B/Ds shall define policies relating to the logging of activities of information systems according to their business needs and data classification. The policies stipulate the mandatory requirements for generating, storing and enabling analysis of recommended data sources. Moreover, B/Ds should define the roles and responsibilities of the staff in log management process to align with the business needs and government security requirements. A sample checklist of log management controls is shown in Annex A for reference.

Operation stage in security log management involves the configuration of logs and process to generate, transmit, store and dispose logs. It also involves the activities to analyse and monitor the log data.

## **4. Security Log Management**

### **4.1 Planning for Security Log Management**

Planning is important for an effective log management. It includes the work to define the roles and responsibilities of staff involved in the log management process and also the work to define the security log management policy.

#### **4.1.1 Define Roles and Responsibilities**

Staff involved in the log management process generally include:

- System administrator
- Network administrator
- Security administrator
- Others (such as incident handling staff)

B/Ds shall clearly define, identify, and authorise the roles and responsibilities of all staff involved in the log management process at a level commensurate with the sensitivity of information. In general, system and network administrators are responsible for log configuration on the systems and network devices, periodic log analysis, log reporting of management activities, and regular log maintenance. Whereas security administrators are responsible for managing and monitoring of the hardware, software, network, and media in log management process, conducting log configuration on security devices, reporting on the security log management activities, etc. In the realm of security log management, there should be segregation of duties between the IT security administrator and the system/network administrator. In order to have sufficient segregation of duties, B/Ds should avoid assigning multiple roles to an individual when sufficient resources are available. For example, log backup process is handled by operational staff while security log data in the backup can only be accessed by staff for monitoring IT security. This type of assignment can help to segregate duties between operational staff and staff for monitoring IT security.

#### **4.1.2 Define Security Log Policy**

Log policy defines the mandatory requirements for generating, storing and enabling analysis of recommended data sources. B/Ds shall define policies relating to the logging of activities of information systems according to its business needs and data classification. The log policy should also include the requirement to regularly monitor the log for any access control discrepancies, breaches, policy violations, and irregular activities (e.g. abnormal massive data download, data access outside working hours), etc. B/Ds shall put in place controls in their systems at the design stage to facilitate the detection of irregular activities. B/Ds can base on log management lifecycle to define and review their logging policy.

Log management lifecycle includes log generation, transmission, storage and disposal. Defining security log policy involves the following considerations in log management lifecycle:

- (1) Log generation – In this process, B/Ds should define the requirements of sources of log to be recorded, the events associated with the source and the level of details of the log data in that event.
- (2) Log transmission – In this process, B/Ds should define the requirements of hosts and log data to be transferred for log management as well as the means and frequency of log transfer. B/Ds should also define the requirements of protecting the confidentiality, integrity, and availability of log data during transfer such as log transmission network protocols and protection mechanism for data during transmission.
- (3) Log storage and disposal – In this process, B/Ds should define the requirements of log capacity management, log rotation and retention, and log disposal. B/Ds should also define the requirements of protecting log data during storage and disposal processes.

Besides the requirements of log management during its lifecycle, the requirements of using logs for monitoring and analysis should also be included in the log policy. The following sections would discuss and provide some best practices on log lifecycle management and log usage. B/Ds can make reference to them when conducting security log management processes.

## 4.2 Security Log Lifecycle Management

Security log management operation includes security log lifecycle management and the monitoring and analysis of security logs. This section will focus on the best practices of security log lifecycle management. The security log monitoring and analysis will be discussed in later section.

Security log lifecycle management consists of three processes, namely:

- Generation
- Transmission
- Storage and disposal

### 4.2.1 Log Generation

Security logs may originate from various sources such as hardware appliances, software systems and applications. Examples include network switch, router, firewall, host OS, security software, web application, and email application etc.

It is ideal to collect all log data from every possible sources as logs contain information about security posture, system health and performance. Nonetheless, excessive logging can generate too much data that may impact the performance of computer system or cause log data overwritten too quickly to render meaningful analysis. In the worst scenario, it can force the system to significantly downgrade its service performance or even stop delivering any service. Hence, it is not practical to collect all possible log data. Therefore, B/Ds should identify which log sources should be monitored and what events/activities should be recorded based on its importance to business, governance and compliance requirements. Prior to implementing logging policies in production environment, it is important to conduct load testing on logging in a testing environment based on planned log configuration.

In general, the log containing the following information should be recorded:

- Any irregularities or system/application errors which are suspected to be triggered as a result of security breaches;
- Any unauthorised accesses or attempts to an information system; and
- Any attempts or access to classified data.

B/Ds should evaluate the importance of the components to business and operation and decide what information to be logged.

In addition, regarding to the risk of improper access to or use of data/information stored in an IT system by person(s) having authorised access to the system, B/Ds should also consider to build in functions in their IT systems to detect irregular activities for drawing management attention and further investigative actions to identify such improper access. The definition of irregular activities depends on the

business operation. Volume and time of data retrieval are some of the considerations in identifying irregular activities.

The following sections will discuss what kind of sources and information needed to be logged.

### (1) Security Log Source

While log data can be generated by many different components in information systems, they generally come from one of the following sources:

- Network infrastructure and services (such as routers, switches, firewalls, etc.)
- Systems and hosts (such as operating systems)
- Applications (such as email application, mission critical systems etc.)

B/Ds should evaluate the risks posed on each IT components and define the list of source to be logged based on its importance to business for security reason.

### (2) Security Log Type

Information security logs are important to incident management, forensic analysis and system monitoring. Generally, security log can be grouped into two types:

- Security Event Log
- System Management Log

#### Security Event Log

A security event is a change to normal or expected behaviour of an information system, consisting of networks, systems, devices and users. Security event logs are key elements in the monitoring of the security posture of information systems and contributing largely to reviews, audits, investigations and incident management.

The following security events are recommended to be logged, including but not limited to:

- Attempts for log-in
- Unauthorised update/access
- Failed attempts for privileges elevation
- Attempts for password changes
- Access attempts to critical files (e.g. software configuration files, password and key files, etc.)
- Actions taken by privileged users

- Use of privileged rights such as addition and deletion of user accounts
- Addition, deletion and modification to permissions of system user and group
- Security related system failures and alerts
- Changes to user access rights
- Failed access attempts to systems and files identified as critical to the system
- Computer services such as file copying or searching
- Modification to audit policy
- Activation and de-activation of protection systems, such as anti-malware systems and intrusion detection systems

### System Management Log

Comprehensive information on the operations of a system can assist system administration, support information security and assist incident investigation and management. In some cases, forensic investigations will rely on the integrity, continuity and coverage of system logs. In this regard, the following system management logs are recommended to be recorded, including but not limited to:

- System start-up and shutdown
- Failures of service, application, component or system
- System maintenance activities
- System backup and archival activities
- System recovery activities
- Out of office hours or unusual activities

### (3) Security Log Details

The level of detail of the log is very important during incident investigation. Any log kept shall provide sufficient information to support comprehensive audits. B/Ds are advised to take a risk-based approach to balance between storage capacity and security needs when deciding the details of each log. The following log details shall be recorded, including but not limited to:

- Start and end date/time of an action
- User identification
- Connection session or terminal
- Action (e.g. read, update, delete)
- Subsystem that performing the action (e.g. process name, process identifier)
- Identifier for the object (e.g. record identifier, computer name, IP address, MAC address)

- Before and after values for update action
- Allowed or denied permission granted to action
- Denied permission

#### (4) Synchronisation of System Internal Clock

Log entries usually contain timestamps which make reference to system clock. If the system clock is inaccurate, the logs may have incorrect timestamps. In this connection, system clocks must be synchronised with an accurate time source. It is a best practice to synchronise system clock periodically to some trusted time server (e.g. clock synchronisation service from Government Backbone Network (GNET) or time server of Hong Kong Observatory) so that audit trails can have a trusted timestamp and event correlation can be performed reliably.

### 4.2.2 Log Transmission

Depending on the importance of the log and operational needs, logs can be stored locally or centralised in a specific location for storage and analysis.

For storing the log centrally, the log information would be transmitted to a central location, B/Ds should, therefore, ensure the reliability of log delivery, the confidentiality and integrity of log during the transmission. Some measures include:

- Apply data encryption, whenever necessary; and
- Implement secure network protocols to prevent protocol attack.

If log transmission is required, B/Ds should also plan and consider the following matters, even though it may not be relevant to security directly:

- Existing and future storage capacity requirement;
- Existing and future network resources requirement;
- Types of IT equipment and their components to transfer logs;
- Log transfer configurations (e.g. compatibility of network protocols, etc.); and
- Frequency of logs to be transferred (e.g. real-time, periodic, etc.).

### 4.2.3 Log Storage and Disposal

As discussed in previous sections, volume of log files can grow very fast especially when the transactions and traffic are in high volume. Normally, the log files are required to be kept for a sufficient period of time for effective monitoring purpose. Insufficient storage or retention period may cause data loss and thus hinder the incident investigation if required. It is, therefore, important to reserve enough storage space for log files and log archives.

The log storage operations involve configuring log rotation, log retention and log disposal. B/Ds need to understand each process and configure log parameters for secure and effective log storage operation.

### (1) Log Rotation

When conducting log configuration, the log file size and actions when maximum log size is reached should be specified. It is recommended to enable log rotation function or install third-party log rotation utility during log configuration. In this case, when log file is full, a new log file will be generated and newly generated log data will be saved in it. As a result, the log data will not be overwritten in a short period of time.

### (2) Log Retention

Log needs to be kept for an extended or considerable period of time as part of standard operational activities or for incident handling or audit practice. This is also known as log archival. As general practice, logs shall be retained for a period commensurate with their usefulness as an audit tool. Log shall also be kept for a period commensurate with the regulatory requirement. The information and retention period of the logs shall also be sufficient to support investigation in the event of breaches of information.

B/Ds should decide the media format for the archival log, such as backup tapes, CDs, DVDs, storage area networks (SAN), network attached storage (NAS), or specialised log archival appliances. B/Ds also need to plan the retention period of the log data based on business needs and risk level of information system.

The following table provides a reference to indicate log retention periods for different types of device and applications with consideration of the criticality of their logging and effectiveness for incident response purposes.

| Log Type               | Log Source Sample                                         | Suggested Minimum Retention Period | Remarks                                                                                                                                    |
|------------------------|-----------------------------------------------------------|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| Infrastructure related | Firewall, Web server, Remote access, Authentication       | 1 year                             | These logs are useful to identify the impact of new and existing persistent threats. Plan storage capacity accordingly to retain the logs. |
| Common applications    | Email, Database, Internet access (including Proxy server) | 6 months                           | These logs are useful for incident investigation.                                                                                          |



| Log Type                | Log Source Sample                                                                | Suggested Minimum Retention Period | Remarks                                                                                                                                   |
|-------------------------|----------------------------------------------------------------------------------|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Security tools/software | Intrusion Detection System (IDS), Anti-virus                                     | 6 months                           | The tools/software often couple with active alerting facilities. Their logs are useful for incident investigation and security reporting. |
| Host related            | Host process execution, File access, Endpoint usage (e.g. USB and printer usage) | 1 month <sup>#1</sup>              | These logs are useful for verification after an intrusion discovered.                                                                     |

#1: B/Ds are recommended to assess and upgrade, if necessary, the storage capacity to implement a retention period commensurate with the impact and criticality of their systems as far as practical, for example, longer retention period is recommended for those related to mission critical systems.

Emails, Internet access, printers and USB devices are some common attacking vectors. B/Ds are recommended to place priority on the log management over areas on Internet access, email, printers and USB usage when considering various sources of logs within the IT environments. It is highly advised to start logging and retaining properly the email, Internet access, printing activities and USB usage if not yet conducted to allow possible investigation of any intrusions and protect the information systems.

Although it is important to maintain log properly, it is important for B/Ds to ensure their staff understand the proper use of mentioned services and devices. The related best practice on proper usage should be communicated properly with end users. Moreover, technical measures can be implemented by B/Ds in protecting government information assets to minimise data leakage.

For proper use of email, please refer to Practice Guide on the Use of Electronic Mail (e-mail). ([https://itginfo.ccgo.hksarg/content/imx/email\\_practice\\_guide.asp](https://itginfo.ccgo.hksarg/content/imx/email_practice_guide.asp))

For performing system logging of user activities related to Internet access, the records of the fixed IP addresses assigned to the workstations or devices, list of dynamic assignment of IP addresses to all network devices, and activity log of B/Ds' own local proxy servers should be maintained. X-Forwarded-For (XFF) header field in such local proxy servers should be enabled to indicate the IP addresses of client workstations. The log should be captured for the following purposes:

- System diagnosis and trouble-shooting;
- Capacity planning and service improvement;
- Identification of IP addresses upon investigation; and
- Provision of information upon B/Ds' request or as required by law.

For more information about the proper use of Internet access, please refer to the Annex B of the Practice Guide for Social Media Security.

(<https://itginfo.ccgo.hksarg/content/itsecure/techcorner/practices.shtml>).

For data loss prevention control through endpoint such as USB, please refer to Practice guide for Data Loss Prevention.

(<https://itginfo.ccgo.hksarg/content/itsecure/techcorner/practices/PracticeGuideDataLossPrev.html>)

Please note that log sources and logging requirements may vary from systems and business needs, it would be difficult to set a unified standard when considering the log retention within an organisation. Besides, log volume of a source may change rapidly due to an upgrade, patch installation, or configuration changes. B/Ds are, therefore, recommended to conduct an assessment of the current and future storage needs for each data source to determine actual log retention time and to ensure sufficient log record is available. The balance between the importance of the system, security considerations, usability and resource usage should be considered. Other factors such as system diagnosis and trouble-shooting or provision of information upon request by B/Ds or as required by law shall also be considered.

### (3) Log Disposal

When legacy log data is no longer needed, the system administrator would remove the log so as to free up the spaces or reuse the media.

B/Ds shall follow the Government security requirements in handling the destruction and disposal of classified information if classified data is involved.

#### (4) Log Capacity Management

The volumes of log data can grow fast. When the storage capacity of log records for some sources reaches its limit, continuous logging may become problematic. B/Ds are recommended to plan log capacity effectively. Following points are references for B/Ds to consider when managing the storage capacity of log data:

- Capacity management plan should be considered for mission critical information systems;
- Capacity requirements should be identified according to the business requirements of the concerned system;
- Sufficient storage capacity shall be made available for log retention based on the retention period defined in the departmental logging policies;
- Old logs should be archived for appropriate length of time and then cleared and disposed when no longer needed according to the B/D's logging requirement and be compliant with the Government requirements in storage media handling;
- Log entries should be timely deleted or cleared when no longer needed; and
- The use of resources should be monitored for capacity management.

#### (5) Security Considerations for Log Protection

As logs may contain records related to information system, the protection of the confidentiality and integrity of log data is equally important as the original data. Therefore, they need to be protected from security breaches. Logs without proper security protection, no matter they are in storage or in transit, are susceptible to intentional and unintentional leakage or tampering. Hence, secure log storage and maintenance of its data confidentiality and integrity are important. Logs should also be protected from unavailability due to storage shortage, data overwriting, data corruption, or data loss. System owners shall review and determine if information in the log file is classified and needs to be protected according to the government security requirements.

The following are some security guidelines to B/Ds for secure storage and disposal of log:

- Logs shall be secured such that they cannot be modified, and can only be read by authorised persons during its retention period;
- Shared account logs should be maintained and periodically reviewed;
- Protect classified log data in a level commensurate to the government requirements;
- Protect archived log files from access, modification and deletion;
- Provide adequate physical protection for archival media; and
- Logs with classified information shall be completely cleared or destroyed from storage media before disposal or re-use.

### 4.3 Security Log Monitoring and Analysis

Regular monitoring of logs shall be conducted for irregularities or system/application errors which are suspected to be triggered as a result of security breaches. Regular log monitoring shall also be conducted on the completeness and the integrity of the log records, in particular the integrity of cyber patrol results for web enforcement. Analysis on the logs to identify potential threats to systems and to trace any security breaches are very important to safeguard the information systems and data. For mission critical systems and end point protection or end point detection and response system, it is recommended to conduct daily checking for logs for early detection of incidence and timely response.

Log files have many kinds of formats, like plain-text, markup languages or binary formats. Some log files can be reviewed and analysed by simple tools, some may require specific tools for analysis as they are in proprietary formats. Understanding of the formats and contents is important for effective log monitoring and analysis.

Following are some guidelines for B/Ds when conducting security log monitoring and analysis:

- Regular checking on log records, especially on system/ application where classified information is processed/ stored, shall be performed;
- Regular checking should be conducted on the completeness and integrity of the log records;
- Regular checking on the access logs should be performed to identify potential security breaches, suspected activities include:
  - Erratic access of privileged accounts
  - Excessive access of privileged accounts in a short period of time
  - Access attempts at unusual times of day
  - Access attempts to information which are not required to know;
- All system and application errors which are suspected to be triggered as a result of security breaches shall be reported;
- Log records should be correlated across different repositories to identify potential security incidents, and operational and security issues;
- Application log, network device and server system logs (e.g. firewall logs, web access logs, system event logs) shall be reviewed regularly to detect anomalies, including those attacks / intrusions on system software or web applications targeting on end users;
- All unauthorised accesses to an information system should be reported and the security violation report should be checked, preferably on a daily basis;
- Use various tools to monitor log files to detect any irregularity or attack;
- Logs shall not be used to profile the activity of a particular user unless it relates to a necessary audit activity as approved by a Directorate rank officer;

- Supervisory checks shall be conducted on log records to detect irregularities;
- Exception reports on log records shall be generated regularly and timely for management attention and actions; and
- Any detected irregularities and the follow-up actions shall be reported to the appropriate authorities for information and further directive as appropriate.

#### 4.4 Security Information and Event Management (SIEM)

Log monitoring and analysis is essential in incident handling and response. To minimise effort and reduce human error, B/Ds should put in place appropriate controls in an IT system at the design stage to facilitate the automatic detection of irregular activities. Tools are developed to assist operators/administrators to perform such tasks. One of the tools is Security Information and Event Management (SIEM). SIEM is a security software product and service combining security information management (SIM) and security event management (SEM) functions. Apart from SIM and SEM functionalities, some SIEM products would also offer additional functionalities such as real-time security alerts analysis, threat verification and incident workflow automation.

SIM automates the collection of event log data from network and security devices/endpoint such as firewalls, proxy servers, intrusion detection systems and anti-virus software. The collected data together with threat intelligence log would be correlated and simplified for long-term storage, analysis and reporting.

SEM provides event management and can import threat for analysis and visual presentation (such as charting and dashboard) for incident response and security operations. It focuses on real-time monitoring, event aggregation, correlation and notification of events from systems such as operating systems, antivirus, firewalls and Intrusion Detection Systems (IDS), as well as events reported directly by authentication systems, servers and databases.

For further details, please refer to Annex B.

\*\*\* ENDS \*\*\*

## Annex A: Sample Checklist of Log Management Controls

| Section 14.4 of Baseline IT Security Policy (S17) and IT Security Guidelines (G3) |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                   | Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Points to check                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>Define Roles and Responsibilities</b>                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 1.                                                                                | <p>[S17-6] and [G3-6]<br/>Evidence used for verification can take form of audit trails, system logs, alarms, or other notifications.<br/>Accountability refers to the ability to audit the actions of all parties and processes which interact with information systems. Roles and responsibilities shall be clearly defined, identified and authorised at a level commensurate with the sensitivity of information.</p> <p>[S17- 7.1.4.]<br/>B/Ds shall apply sufficient segregation of duties to avoid execution of all security functions of an information system by a single individual.</p> <p>[G3-7.1 (c)]<br/>There shall be sufficient segregation of duties with roles and responsibilities clearly defined so as to minimise the chance that a single individual will have the authority to execute and control all security functions or critical operations of an information system.</p> <p>In situations where a segregation of duties is not practicable, compensating controls should be put in place to provide the equivalent safeguards, e.g. by maintaining appropriate logging on critical operations conducted by the staff together with random inspection and/or regular review on the log file by an appropriate level of authority.</p> | <p>For System: _____</p> <p>Please list the post and name of the following roles:</p> <p>1) System administrator: _____<br/> 2) Network administrator: _____<br/> 3) Security administrator: _____<br/> 4) Others (such as incident handling staff): _____</p> <p>List the post and name of staff responsible for random inspection and/or regular review on the log file in case segregation of duties cannot be implement:<br/> Post: _____<br/> Name: _____</p> |

| Log Policy |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2.         | <p>[S17-14.4.1]<br/>B/Ds shall define policies relating to the logging of activities of information systems under their control according to the business needs and data classification.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | <p>5) Is logging policy defined?</p> <p>_____</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| 3.         | <p>[G3-14.4 (a) Para. 5]<br/>The policies shall include but not be limited to the requirement to log:</p> <ul style="list-style-type: none"> <li>• Attempts for log-in.</li> <li>• Attempts for password changes.</li> <li>• Access attempts to critical files (e.g. software configuration files, password and key files, etc.).</li> <li>• Use of privileged rights such as addition and deletion of user accounts.</li> <li>• Changes to user access rights.</li> <li>• Modification to audit policy.</li> <li>• Activation and de-activation of protection systems, such as anti-malware systems and intrusion detection systems.</li> </ul> <p>Failure to log the above activities shall be justified and documented.</p> | <p>6) What are the details of logging policy?</p> <p>_____</p> <p>7) Are there any requirements that are not included in your logging policy?</p> <p>_____</p> <p>8) What is the justification for not including the mentioned requirements?</p> <p>_____</p>                                                                                                                                                                                                                                                                                                          |
| 4.         | <p>[G3-14.4 (a) Para. 11]<br/>B/Ds should take the following considerations into account when defining and reviewing their logging policies:</p> <p>[G3-14.4 (a) Para. 11 (i)]<br/>Log generation</p> <ul style="list-style-type: none"> <li>• Types of IT equipment and their components (e.g. applications, database, etc.) to generate logs.</li> <li>• Types of events to be logged.</li> <li>• Details for each type of events to be logged (e.g. username, source IP address, time stamps, etc.).</li> <li>• Clock synchronisation requirements (e.g. trusted time source, date and time format, synchronisation method and frequency, etc.).</li> </ul>                                                                 | <p>For each and every IT equipment and their components, please specify:</p> <p>Log generation:</p> <p>9) Types of IT equipment and their components (e.g. applications, database, etc.) to generate logs:</p> <p>_____</p> <p>10) Types of events to be logged:</p> <p>_____</p> <p>11) Details for each type of events to be logged (e.g. username, source IP address, time stamps, etc.):</p> <p>_____</p> <p>12) Clock synchronisation requirements (e.g. trusted time source, date and time format, synchronisation method and frequency, etc.):</p> <p>_____</p> |

|    |                                                                                                                                                                                                                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                |
|----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5. | <p>[G3-14.4 (a) Para. 11 (ii)]<br/>Log transmission</p> <ul style="list-style-type: none"> <li>• Types of IT equipment and their components to transfer logs to central log management infrastructure.</li> <li>• Log delivery requirements (e.g. network protocols, etc.).</li> <li>• Frequency of logs to be transferred (e.g. real-time, every hour, etc.).</li> </ul> | <p>For each and every IT equipment and their components, please specify:</p> <p>Log transmission:</p> <p>13) Types of IT equipment and their components to transfer logs to central log management infrastructure:</p> <p>14) Log delivery requirements (e.g. network protocols, etc.):</p> <p>15) Frequency of logs to be transferred (e.g. real-time, every hour, etc.):</p> |
| 6. | <p>[G3-14.4 (a) Para. 11 (iii)]<br/>Log storage and disposal</p> <ul style="list-style-type: none"> <li>• Log protection requirements (e.g. access control, etc.).</li> <li>• Log storage space.</li> <li>• Criteria for log rotation.</li> <li>• Log retention period based on risk level of information system.</li> </ul>                                              | <p>For each and every IT equipment and their components, please specify:</p> <p>Log storage and disposal:</p> <p>16) Log protection requirements (e.g. access control, etc.):</p> <p>17) Log storage space:</p> <p>18) Criteria for log rotation:</p> <p>19) Log retention period based on risk level of information system:</p>                                               |
| 7. | <p>[G3-14.4 (a) Para. 11 (iv)]<br/>Log analysis</p> <ul style="list-style-type: none"> <li>• Roles and responsibilities</li> <li>• Type of events to trigger alerts to responsible parties.</li> <li>• Type of events to be analysed.</li> <li>• Log review frequency.</li> <li>• Handling procedures for suspicious and abnormal activities.</li> </ul>                  | <p>For each and every IT equipment and their components, please specify:</p> <p>Log analysis:</p> <p>20) Roles and responsibilities:</p> <p>21) Type of events to trigger alerts to responsible parties:</p> <p>22) Type of events to be analysed:</p> <p>23) Log review frequency:</p> <p>24) Handling procedures for suspicious and abnormal activities:</p>                 |



| Log Generation             |                                                                                                                                                                                                                                                                                                                       |                                                                                                                                           |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| <u>Security Log Source</u> |                                                                                                                                                                                                                                                                                                                       |                                                                                                                                           |
| 8.                         | [G3-14.4 (b) Para. 2]<br>In addition to the application log, network device and server system logs (e.g. firewall logs, web access logs, system event logs) shall also be reviewed regularly to detect anomalies, including those attacks / intrusions on system software or web applications targeting on end users. | 25) Application:<br>_____<br>26) Network Device:<br>_____<br>27) Server System:<br>_____<br>28) Database:<br>_____                        |
| 9.                         | [G3-14.4(a) Para. 8]<br>Logs of Approved Email System and Internet access service centrally provided by DPO or B/Ds shall be recorded.                                                                                                                                                                                | 29) Email System:<br>_____<br>30) Internet Access Service:<br>_____                                                                       |
| 10.                        | [G3-14.4(a) Para. 9]<br>Security controls, including but not limited to blocking connection of unauthorised removable media such as USB storage devices, logging printing activities and file transfer activities to removable media, should be applied.                                                              | 31) Printers:<br>_____<br>32) File transfer activities to removable media:<br>_____                                                       |
| 11.                        | [G3-14.4 (a) Para. 14]<br>Audit trail and logging features shall be enabled on standalone PC or workstation when classified data is stored on its hard drive.                                                                                                                                                         | 33) List of standalone PC and workstation with classified information:<br>_____<br>34) What event was enabled for audit trail?<br>_____   |
| 12.                        | [G3-14.4 (a) Para. 13]<br>Systems containing information classified as CONFIDENTIAL or above require mandatory audit trail on all shared access to the data.                                                                                                                                                          | 35) List of systems containing CONFIDENTIAL or above:<br>_____<br>36) Is audit trail enabled for shared access in these systems?<br>_____ |

| <i>Security Event Log</i> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 13.                       | <p>[G3-14.4 (a) Para. 5]<br/>shall include but not be limited to the requirement to log:</p> <ul style="list-style-type: none"> <li>• Attempts for log-in.</li> <li>• Attempts for password changes.</li> <li>• Access attempts to critical files (e.g. software configuration files, password and key files, etc.)</li> <li>• Use of privileged rights such as addition and deletion of user accounts.</li> <li>• Changes to user access rights</li> <li>• Modification to audit policy.</li> <li>• Activation and de-activation of protection systems, such as anti-malware systems and intrusion detection systems.</li> </ul> <p>[G3-14.4 (a) Para. 6]<br/>Failure to log the above activities shall be justified and documented.</p> <p>[G3-14.4 (b) Para. 1]<br/>Any irregularities or system/application errors which are suspected to be triggered as a result of security breaches, shall be logged and reported.</p> | <p>Security event log for source _____ :</p> <p>37) Attempts for log-in:<br/>_____</p> <p>38) Attempts for password changes:<br/>_____</p> <p>39) Access attempts to critical files (e.g. software configuration files, password and key files, etc.):<br/>_____</p> <p>40) Use of privileged rights such as addition and deletion of user accounts:<br/>_____</p> <p>41) Changes to user access rights:<br/>_____</p> <p>42) Modification to audit policy:<br/>_____</p> <p>43) Activation and de-activation of protection systems:<br/>_____</p> <p>44) Justification and documentation for not log any of the above activities:<br/>_____</p> <p>45) Irregularities or system/application errors which are suspected to be triggered as a result of security breaches:<br/>_____</p> |

| <u>Security Log Details</u> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                                                                                                                                                                                                                                                                                                                                                                                                        |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 14.                         | <p>[G3-14.4 (a) Para. 4]Logs can contain the following information, but are not limited to:</p> <ul style="list-style-type: none"> <li>• Unauthorised update/access.</li> <li>• Starting/ending date and time of activity.</li> <li>• User identification (for illegal logon).</li> <li>• Sign-on and sign-off activity (for illegal logon).</li> <li>• Connection session or terminal.</li> <li>• Computer services such as file copying, searching.</li> </ul> <p>[S17-14.4.2]<br/>Any log kept shall provide sufficient information to support comprehensive audits of the effectiveness of, and compliance of security measures</p> | <p>Security Detail for Event: _____:</p> <p>46) Unauthorised update/access:<br/>_____</p> <p>47) Start/end date and time of activity:<br/>_____</p> <p>48) User identification (for illegal logon):<br/>_____</p> <p>49) Sign-on and sign-off activity (for illegal logon):<br/>_____</p> <p>50) Connection session or terminal:<br/>_____</p> <p>51) Computer services such as file copying, searching:<br/>_____</p> |
| 15.                         | <p>[G3-14.4(a) Para. 8]<br/>For email log, the fields shall include but are not limited to sending date/time, client IP address, sender and recipient email addresses, and total email size.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                        | <p>Security Detail for Event: _____:</p> <p>52) Fields to be captured:<br/>_____<br/>_____<br/>_____<br/>_____<br/>_____<br/>_____</p>                                                                                                                                                                                                                                                                                 |
| 16.                         | <p>[G3-14.4(a) Para. 8]<br/>For Internet access log, the fields shall include but are not limited to access date/time, client IP address, access website or URL.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | <p>Security Detail for Event: _____:</p> <p>53) Fields to be captured:<br/>_____<br/>_____<br/>_____</p>                                                                                                                                                                                                                                                                                                               |

|                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | <hr/> <hr/>                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| 17.                                             | <p>[G3-14. 4(a) Para. 9]<br/>Security controls, including but not limited to blocking connection of unauthorised removable media such as USB storage devices, logging printing activities and file transfer activities to removable media, should be applied.</p>                                                                                                                                                                                                                                            | <p>Security Detail for Printer:</p> <hr/> <p>54) Fields to be captured the workstation initiated the print job:</p> <hr/> <p>Name of document printed:</p> <hr/> <p>date and time of the print job:</p> <hr/> <p>Security Detail for USB storage devices:</p> <hr/> <p>55) Fields to be captured the workstation connected by removable media:</p> <hr/> <p>Name of document transferred:</p> <hr/> <p>date and time of the file transfer:</p> <hr/> |
| <i>Synchronisation of System Internal Clock</i> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| 18.                                             | <p>[S17-14.4.6]<br/>The clocks of information systems shall be synchronised to a trusted time source.</p> <p>[G3-14.4 (a) Para.15]<br/>Information systems shall synchronise its clock with a trusted time server periodically (at least once per month). B/Ds should use the clock synchronisation service from GNET or use the time server of Hong Kong Observatory via the Network Time Protocol (NTP). Authentication in NTP can be considered to enhance security in clock synchronisation process.</p> | <p>For log source: _____</p> <p>56) Time server:</p> <hr/> <p>57) Clock synchronisation frequency:</p> <hr/> <p>58) Security measures in clock synchronisation process:</p> <hr/>                                                                                                                                                                                                                                                                    |

| <b>Log Transmission</b>         |                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                |
|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 19.                             | <p>[G3-14.4(a) para 11 (ii)]</p> <ul style="list-style-type: none"> <li>Types of IT equipment and their components to transfer logs to central log management infrastructure.</li> <li>Log delivery requirements (e.g. network protocols, etc.).</li> <li>Frequency of logs to be transferred (e.g. real-time, every hour, etc.).</li> </ul> | <p>59) List the types of IT equipment and their components to transfer logs to central log management if any:</p> <p>_____</p> <p>60) Log transfer protocol used:</p> <p>_____</p> <p>61) Frequency of logs to be transferred:</p> <p>_____</p> <p>62) Any encryption to log during transmission:</p> <p>_____</p> <p>63) Is there any log containing classified information?</p> <p>_____</p> |
| <b>Log Storage and Disposal</b> |                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                |
| <u>Log Rotation</u>             |                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                |
| 20.                             | <p>[G3-14.4(a) para 11 (iii)]</p> <p>Criteria for log rotation</p>                                                                                                                                                                                                                                                                           | <p>For log source: _____</p> <p>64) Please specify the criteria for log rotation:</p> <p>_____</p>                                                                                                                                                                                                                                                                                             |
| <u>Log Retention</u>            |                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                |
| 21.                             | <p>[S17-14.4.3] [G3-14.4 (a) Para. 8]</p> <p>Logs shall be retained for a period commensurate with their usefulness as an audit tool.</p> <p>The retention period for log of Approved Email System and Internet access service centrally provided by DPO or B/Ds shall be no less than six months.</p>                                       | <p>65) Critical log source:</p> <p>_____</p> <p>66) Retention period for critical log:</p> <p>_____</p> <p>67) Important log source:</p> <p>_____</p> <p>68) Retention period for important log:</p> <p>_____</p> <p>69) Regular log source:</p> <p>_____</p> <p>70) Retention period for regular log:</p> <p>_____</p>                                                                        |
| 22.                             | <p>[G3-14.4 (a) Para. 10]</p> <p>The information and retention period of the logs shall also be sufficient to</p>                                                                                                                                                                                                                            | <p>71) Is the sufficiency of the log to support investigation on breach of security evaluated?</p>                                                                                                                                                                                                                                                                                             |

|                                |                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                               |
|--------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                | support investigation on breach of security.                                                                                                                              | _____                                                                                                                                                                                                                                                                                                                                                                         |
| <i>Log Disposal</i>            |                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                               |
| 23.                            | [S17-10.3.3] All classified information shall be completely cleared or destroyed from storage media before disposal or re-use.                                            | 72) Log with classified information to be disposed:<br>_____<br>73) Media handling method before disposal or re-use of the media:<br>_____                                                                                                                                                                                                                                    |
| <i>Log Capacity Management</i> |                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                               |
| 24.                            | [G3-14.4 (a) Para. 14]<br>Sufficient hard disk size shall be made available for log retention based on the retention period defined in the departmental logging policies. | For log source:<br>_____<br>74) Importance of the log (Regular/ Important/Mission Critical):<br>_____<br>75) Retention period:<br>_____<br>76) Log rotation policy:<br>_____<br>77) Daily growth rate of log:<br>_____<br>78) Storage allocation:<br>_____<br>79) Is storage capacity plan developed?<br>_____<br>80) Is the storage sufficient to support the plan?<br>_____ |
| 25.                            | [G3-14.4 (c) Para. 1]<br>The use of resources should be monitored for capacity management.                                                                                | Refer to item 24                                                                                                                                                                                                                                                                                                                                                              |
| 26.                            | [G3-14.4 (c) Para. 1]<br>Capacity requirements should be identified according to the business requirements of the concerned system.                                       | Refer to item 24                                                                                                                                                                                                                                                                                                                                                              |
| 27.                            | [G3-14.4 (c) Para. 1]<br>A capacity management plan should be considered for mission critical                                                                             | 81) List of Mission Critical Information Systems:<br>_____                                                                                                                                                                                                                                                                                                                    |

|                       |                                                                                                                                                                                                                                                                                                                             |                                                                                                                                                                                                                                                                             |
|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                       | information systems.                                                                                                                                                                                                                                                                                                        | 82) Log source:<br>_____<br>83) Capacity management plan exists?<br>_____                                                                                                                                                                                                   |
| 28.                   | [G3-14.4 (c) Para. 1]<br>Staff in charge of budgeting should take into account the demands in capacity management plan.                                                                                                                                                                                                     | 84) Does the budget include the demands in capacity management plan?<br>_____                                                                                                                                                                                               |
| <b>Log Protection</b> |                                                                                                                                                                                                                                                                                                                             |                                                                                                                                                                                                                                                                             |
| 29.                   | [S17-14.4.3] [G3-14.4 (a) Para. 10]<br><br>Logs shall be secured such that they cannot be modified, and can only be read by authorised persons during its retention period. B/Ds should consider managing their logs by centralised log management.                                                                         | For log source:<br>_____<br>85) Log protection method/tool:<br>_____<br>86) Log access control:<br>_____<br>87) Centralised log management system in used:<br>_____                                                                                                         |
| 30.                   | [G3-14.4 (a) Para. 12]<br>Shared accounts to logs should be maintained and periodically update for shared/group accounts with information including, but not limited to, system name, user name (in person) who can share the account, shared user-ID, permission(s) granted, account valid period, and reason for sharing. | For log source:<br>_____<br>88) Shared account list:<br>_____<br>89) Log update frequency:<br>_____<br>90) Shared account user name:<br>_____<br>91) Shared user-ID:<br>_____<br>92) Permission:<br>_____<br>93) Valid period:<br>_____<br>94) Reason for sharing:<br>_____ |

|                                 |                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                        |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 31.                             | [G3-16.1 (c) Para. 1]<br>Maintain audit trails for important events such as critical operation or processing of sensitive information, for routine control or investigation purposes; tampering with or changes to any audit trails should be prohibited; management attention should be drawn to exceptional circumstances. | 95) Are audit trails maintained for important events?<br>_____<br>96) Are the audit trails properly protected?<br>_____                                                                                                                                                                |
| <b>Log Monitor and Analysis</b> |                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                        |
| 32.                             | [S17-14.4.4] [G3-14.4 (a) Para. 7]<br>Logs shall not be used to profile the activity of a particular user unless it relates to a necessary audit activity or incident handling as approved by a Directorate officer.                                                                                                         | 97) Are the logs used to profile the activity of a particular user?<br>_____                                                                                                                                                                                                           |
| 33.                             | [S17-14.4.5] [G3-14.4 (b) Para. 1]<br>Regular checking on log records, especially on system/ application where classified information is processed/ stored, shall be performed                                                                                                                                               | 98) Is log checking performed regularly?<br>_____<br>99) Post and Name of staff responsible for log checking:<br>_____<br>100) What is the checking frequency?<br>_____                                                                                                                |
| 34.                             | [S17-14.4.5] [G3-14.4 (b) Para. 1]<br>Regular checking on log records, especially on system/application where classified information is processed/stored, shall be performed, not only on the completeness but also the integrity of the log records                                                                         | 101) Is checking on log completeness performed regularly?<br>_____<br>102) Is checking on log integrity performed regularly?<br>_____                                                                                                                                                  |
| 35.                             | [G3-14.4 (b) Para. 1]<br>Any irregularities or system/application errors which are suspected to be triggered as a result of security breaches, shall be logged and reported.                                                                                                                                                 | 103) Are all irregularities or system/application errors which are suspected to be triggered as a result of security breaches logged and reported?<br>_____<br>104) Are log irregularities detection be included in operator manual as security incident handling procedures?<br>_____ |



|               |                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                             |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 36.           | [G3-14.4 (b) Para. 2]<br>Log records should also be correlated across different repositories to identify potential security incidents, and operational and security issues.  | 105) Are the logs correlated across different repositories to identify potential security incidents, and operational and security issues?<br>_____<br><br>106) List of log sources which can be correlated for identification of potential security incidents and operational and security issues:<br>_____ |
| 37.           | [G3-14.4 (b) Para. 2]<br>All unauthorised accesses to an information system should be reported and security violation report should be checked, preferably on a daily basis. | 107) Are all unauthorised accesses to an information system reported?<br>_____<br><br>108) What is the frequency on checking security violation report?<br>_____<br><br>109) Name and post of staff responsible for checking security violation report:<br>_____                                            |
| 38.           | [S17-14.4.5]<br>All system and application errors which are suspected to be triggered as a result of security breaches shall be reported and logged                          | 110) Are all system and application errors which are suspected to be triggered as a result of security breaches reported and logged?<br>_____                                                                                                                                                               |
| <b>Others</b> |                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                             |
| 38.           | [G3-14.4 (b) Para. 2]<br>Tight change control procedures should be established for system software for detecting unauthorised usage.                                         | 111) Is there any change control procedure for detecting unauthorised usage?<br>_____<br>112) Please specify, if any.<br>_____                                                                                                                                                                              |

## **Annex B: Security Information and Event Management (SIEM)**

SIEM aims to use rules and statistical correlations to turn log entries and events data from endpoint, hosts, network and security devices into useful information. Such information can help administrators identify anomalies and vulnerabilities, detect threats in real time, manage incident response, perform investigation on past security incidents, and prepare audits for compliance purposes.

Besides, the notifications and alerts, like early detection of targeted attacks, advanced threats, and data breaches can be sent to administrators for further actions to prevent malicious cyber attacks.

### **B.1 Features in SIEM**

Below lists some of the features in SIEM, including but not limited to:

- gather, analyse and display information from endpoints, hosts, network and security devices
  - identity and access management applications
  - vulnerability management and policy compliance tools
  - operating system, database and application logs
  - external threat data
- monitor and help manage user and service privileges, directory services and other system configuration changes
- provide log auditing and review and incident response

### **B.2 Centralised Log Management Infrastructure in SIEM**

The processing and management of huge volume of event and log data is an important part in SIEM. To have a centralised platform for SIEM to handle the logs and ensure components and capabilities interact with each other smoothly without time delay, a centralised log management infrastructure is vital to achieve the goal.

Besides, a centralised log management infrastructure can help streamline the troubleshooting and log analysis, improve the operational efficiency of log management, provide real-time monitoring in graphical view and provide remedial actions against the threats immediately.

## B.3 SIEM Capabilities

SIEM has various capabilities to support security threat detection and responds to security incidents in the organisations. Besides, it offers rule-based insights after analysing huge volume of events and other data.

### B.3.1 Core capabilities

- Data Aggregation

To aggregate data from various sources, including network, endpoints, servers, databases, applications, and other security systems like firewalls, anti-virus and Intrusion Detection Systems / Intrusion Prevention Systems (IDS/IPS).

The following is the list of source logs for data ingestion in SIEM, including but not limited to:

- Intrusion detection systems/intrusion prevention systems (IDS/IPS)
- Data Loss Prevention (DLP)
- Anti-virus and other endpoint security software
- Firewalls
- Unified Threat Management (UTM) systems
- Network, routers and switches
- Wireless access points
- Application servers, intranet application and databases especially mission critical systems
- Endpoints (e.g. application, cloud, mobile, IoT)

- Threat intelligence feeds

To combine internal data with threat intelligence feeds containing data on vulnerabilities, threat actors and attack patterns.

- **Correlation and analytics**

The technique links the events and related data and integrates with different source together. By using correlation, statistical models and rule-based algorithm, the system identifies deeper relationships between data elements, and anomalies compared to known trends, and provide useful information covering security incident, threat or vulnerability findings.
- **Security alerts**

To conduct rule-based analysis of correlated events and generate security alerts to notify security team to take immediate actions.
- **Dashboard**

To display data or information in graphical charts in dashboard and allow users to view the event data and identify abnormal activities.
- **Compliance**

By gathering compliance data, the system generates the audit reports to meet security standards and compliance regulations (e.g. The Personal Information Protection Law (PIPL) of the People's Republic of China, GDPR, SOX, HIPPA and PCI DSS).
- **Retention**

To setup the security log retention period to meet compliance requirement. Long term historical data is critical for incident investigations.
- **Incident analysis**

This helps security team discover the details of security breach and incidents as well as determine what systems and sensitive information are compromised. This capability improves cyber security against threats and reduces response time to incidents significantly.

With evolving of emerging technologies, some new capabilities are available in advanced features of SIEM to improve the detection and response to

targeted attacks and breaches and optimise the security operation in the organisations.

### B.3.1.1 Advanced capabilities

- User and Entity Behaviour Analytics (UEBA)

The system monitors and analyses user behaviour, detects abnormal behaviour, and figures out any anomalous behaviour that may impact security. UEBA triggers alerts when unusual entity or user behaviour is observed.

Besides, UEBA identifies anomalous attacks and incidents, including zero day attacks and insider threats. This can help the organisation react to incident response more quickly and accurately.

- Security Orchestration Automation and Response (SOAR)

SOAR leverage SIEM technology to become more intelligence and drive big data analytic. It helps security team make better and reliable decision and respond to security threats quickly with the aid of automation.

SOAR is a tool to perform

- Collect security threat data and alerts from different sources
- Enable incident analysis, triage and prioritization, both automatically and manually
- Define and enforce a standard workflow for incident response activities
- Encode incident analysis and response procedures in a digital workflow format, enabling automation of some or all incident responses

SOAR technology covers three key capabilities:

- Security orchestration and automation (SOA)  
To support the automation and orchestration of workflows, processes, policy execution and reporting
- Security incident response (SIR)

To support how an organisation plans, manages, tracks and coordinates the response to a security incident

- Threat intelligence platform (TIP)

To support the remediation of vulnerabilities. It provides formalised workflow, reporting and collaboration capabilities.

- Network Traffic and Behaviour Analytics (NTBA)

By analysing network traffic from switches and routers, NTBA provides real-time network visibility and network threat protection. It identifies risky behaviour in the network and prevents stealthy attacks effectively. It also evaluates network-level threats and detects anomaly behaviour, including malware, zero-day, botnets and worm attacks.

- Artificial Intelligence (AI)

AI in SIEM helps security team to automate tasks without manual and repetitive work, reduce the chances of human errors caused by human intervention, eliminate blind spots and increase the productivity of security team. It learns and identifies potential threats and new anomalies by analysing huge volumes of data in a short time. It perceives significant hidden relationships and predicts future threats.

### B.3.2 Advantages and Disadvantages of SIEM

Advantages:

- Offer a centralised view of data from various sources
- Enhance threat detection
- Improve security threat prevention
- Handle security incident efficiently
- Simplify audit and compliance reporting

Limitations:

- Require extra resources in procurement of software/system
- Innumerable false positive alerts

- Require extra resources to train staff to operate SIEM
- Require regular monitoring of SIEM operation